

L2 - 10.4. Post Incident Activity

Task 1 - Introduction

The attacker has been contained, eradicated, and the environment is clean. But the work is not finished. The final phase of the NIST incident response framework is Post-Incident Activity, the phase where the organization steps back, reflects on what happened, documents the findings, and uses everything learned to become harder to attack next time.

Task 2 - Learning From The Incident

Every security incident contains valuable information that can help the SOC to mature its defense capabilities. The attacker's methods, the gaps they exploited, the controls that failed, and the controls that worked, all of it is intelligence that can be used to strengthen the organization's defenses. The Post-Incident Activity phase is where this intelligence is gathered.

NIST SP 800-61r2 describes this phase as an opportunity to identify how to improve the incident-handling process. It is important to note that this Post-Incident phase is not just a formality. It is where the real long-term value of incident response is generated. An organization that skips this phase learns nothing from what happened and remains just as vulnerable to the same attack.

The Lessons Learned Meeting

The lessons learned meeting is a structured discussion held after the incident is resolved. It brings together everyone involved in the response, the IR team, relevant stakeholders, and, in some cases, IT and management, to review what happened and what can be improved. The meeting addresses the following questions:

- What exactly happened, and what was the root cause?
- How did the attacker gain initial access, and what vulnerability was exploited?
- When was the incident detected, and what triggered the detection?
- Could it have been detected earlier, and if so, how?
- What went well during the response, and what did not?

- What changes to people, processes, or technology would prevent this from happening again?

The answers to these questions serve as inputs for improving IR capability. New detection rules, updated policies, additional training, and changes to the technology stack all result from this process.

Why This Phase Often Gets Skipped

Post-Incident Activity is the most commonly skipped phase in incident response. There are a few reasons. After an incident, the team is tired, stakeholders want to move on, and there is always another alert to triage. The immediate pressure to return to normal operations leaves little appetite for reflecting back on the lessons.

But skipping this phase can be damaging. The same vulnerabilities remain open. The same detection gaps persist. The next attacker who uses the same technique will succeed just as easily. The lessons-learned process prevents an organization from fighting the same battle repeatedly.

Closing the NIST Cycle

The NIST SP 800-61r2 connects Post-Incident Activity back to Preparation. Everything learned in this phase improves the organization's readiness for the next incident. Updated IR policies, new detection rules, better-trained staff, and improved visibility all feed back into the Preparation phase. This makes incident response a continuous improvement process rather than a one-time event.

Answer the questions below

What is the name of the structured discussion held after an incident to review what happened and identify improvements?

Lessons learned meeting

According to NIST SP 800-61r2, which phase does Post-Incident Activity feed back into?

Task 3 - Reporting the Incident

After a security incident, the IR team is responsible for producing documentation for two very different audiences. First, the technical staff needs a detailed record of what happened, what was found, and what was done. Second, the leadership

and stakeholders need a clear, concise account of the business impact and the actions taken to resolve it. These two are covered by two different documents: the technical summary and the executive summary.

The Executive Summary

The executive summary is written for a non-technical audience. Its purpose is to clearly and concisely communicate the business impact of the incident. The CIO, CEO, legal counsel, and board members are typical readers of an executive summary. A good executive summary should cover the following:

Category	Details
What Happened	Describe in simple language what type of attack occurred and what systems or data were affected.
Business Impact	Summarise whether data was lost, operations were disrupted, and whether there is any regulatory exposure.
How It Was Discovered & Resolved	Provide a high-level timeline of how the incident was detected and what steps were taken to resolve it. This should not include technical indicators.
Prevention & Remediation	Outline the actions being taken to prevent recurrence, described in plain language.

What an executive summary should not contain: IP addresses, domain names, MITRE technique IDs, SPL queries, or any other technical detail that is not relevant to a business audience. Including these details makes the document harder to read and dilutes the key messages.

The Technical Summary

The technical summary is intended for all technical teams, including the IR team, security engineers, and IT staff. Its purpose is to provide a complete and precise record of the incident that can be used for evidence, future reference, and as a basis for improving defenses. A good technical summary should cover the following:

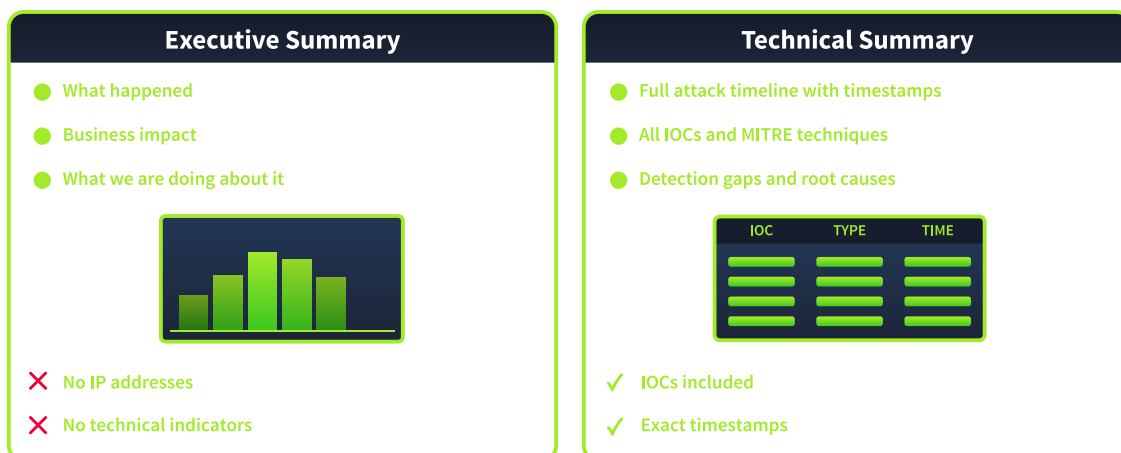
Category	Details
Full Attack Timeline	Every event in sequence with exact timestamps from the logs, from the first malicious action to containment.

Category	Details
IOCs	All indicators of compromise discovered during the investigation, including IP addresses, domains, email addresses, file names, and account names.
MITRE ATT&CK Techniques	Every technique that was identified during the incident, with specific details on how it was executed in this incident.
Log Evidence	The specific log sources, queries, and raw log entries used to confirm each finding.
Root Causes	The security control gaps that allowed the incident to occur and the remediation steps taken to address them.
Detection Gaps	The attacker behaviors that were not caught by existing alerts, and the detection rules added as a result.

On the MITRE techniques row, a common mistake in IR reports is listing technique IDs without any supporting detail. Writing T1564.008 in a report means very little to the next analyst who reads it. What makes a technique entry genuinely useful is the specific context: what exactly was created or executed, what it looked like in the logs, when it happened, and what the exact indicators were. For example, documenting T1564.008 in this incident should include the exact name of the inbox rule, the keywords it filtered for, the action it performed, the account it was created on, and the UAL timestamp. That level of detail is what allows detection rules to be written from the report and what gives the technical summary its investigative value long after the incident is closed.

The IOC Tracker developed during this investigation will act as the starting point for the technical summary. Every entry in the tracker shows a specific attacker action, which should be documented in full technical detail.

	Executive Summary	Technical Summary
Audience	Leadership, legal, stakeholders	IR team, security engineers, IT
Language	Plain business language	Technical and precise
IOCs included	No	Yes, all of them
Timeline detail	High level only	Full with exact timestamps
Purpose	Inform and reassure leadership	Record and improve defenses



Answer the questions below

What type of incident report is written for a non-technical audience, such as leadership and legal counsel?

Executive summary

Which report type would contain specific IOCs, MITRE technique IDs, and exact timestamps?

Technical summary

Task 4 - Strengthening the Defenses

The TTPs (Tactics, Techniques, and Procedures) identified during this investigation are a source of intelligence that can be used to create detection rules. So the same attack can be identified more quickly in the future. The IOC Tracker built across this investigation captures these TTPs alongside their specific indicators, making it the starting point for building new detection logic.

From TTPs to Detection Rules

Every TTP (Tactic, Technique, and Procedure) identified during the investigation corresponds to a specific attacker behavior recorded in the logs. This is where many organizations improve after an incident. Not everything will be covered by alerts before an attack happens. But after an incident, the IR team has a clear picture of exactly what the attacker did, and can create targeted detection rules based on those specific techniques. The next time an attacker uses the same

approach, the SOC will know within minutes rather than hours or days. This is what forms a **Post-Incident Activity → Preparation** loop; the lessons learned in the last phase feed back to the first phase.

The False Positive Problem

Writing a good detection rule is difficult. The challenge is that many attacker behaviors are similar to those of normal users. Creating an inbox rule is something employees do regularly for legitimate reasons. Downloading files from SharePoint is normal. Signing in from a new location can also mean someone is traveling.

A detection rule that alerts on every inbox rule creation would generate hundreds of alerts per day in a typical organization. In this case, the SOC teams would spend most of their time triaging false positives, while the actual threats would go unnoticed. This is called alert fatigue, and it is one of the most common problems in security operations.

Good detection rules catch attacker behavior by looking for anomalies, combinations of events (correlation), or conditions that are unusual, even if any single action looks normal on its own. For example:

- An inbox rule created by an account that signed in from a new country in the last hour
- A large number of files downloaded from SharePoint within a short timeframe from a single account
- A successful sign-in from an IP address that has never been seen in the environment before, with no MFA
- An external sharing event on a sensitive file immediately following an anomalous sign-in

None of the above-mentioned individual actions is necessarily malicious on its own. But together, or in the context of surrounding events, they can form a pattern that is worth alerting on. This is the difference between a rule that catches attacker behavior and one that only generates noise. If you want to explore best practices on writing detection rules, the **Developing Detection Rules** room (coming soon) is a great place to start your learning.

Post-Incident Detection as a Learning Curve

It is important to understand that no organization has perfect detection coverage before an incident. Detection engineering is not one-time. It is an ongoing process. Every incident teaches the security team something new about attacker behavior and gives them the opportunity to add detection rules they did not have before.

After the Nexus Financial incident, the IR team now knows exactly which techniques the attacker used and in what sequence. Each technique that was not caught by an existing alert is a candidate for a new detection rule. Over time, as more incidents are investigated and more rules are added, the organization's detection coverage matures. Detection engineering is a completely different area and falls outside this module's scope.

Post-Incident Investigation Tools for Microsoft 365

Since this incident involved a Microsoft 365 compromise, it's important to know that several tools are designed specifically for post-incident investigation of Microsoft 365 environments. These can help detect activity that may not be visible in standard audit logs and provide a final confirmation that the environment is clean before the incident is formally closed.

Incident Response Tools

Tool	Description
Hawk	It is an open-source PowerShell tool for gathering forensic data from Microsoft 365 environments, including mailbox activity, admin actions, and sign-in logs.
Sparrow	It was developed after high-profile cloud incidents. Sparrow checks for indicators of compromise specific to Microsoft 365 and Azure environments.
Microsoft Secure Score	It is a measurement of the organization's security posture across Microsoft 365 services, useful for identifying remaining gaps after an incident.

Answer the questions below

What term describes the situation where too many alerts are generated, causing analysts to miss real threats?

Alert fatigue

What Microsoft tool measures an organization's security posture across Microsoft 365 services?

Microsoft Secure Score

Task 5 - Current Incident Context

The incident started with a SIEM alert that was raised by Marcus Webb, Nexus Financial's L1 Security Analyst. Below is the alert and the escalation ticket Marcus raised after triage.

Alert Details:

- **Alert Name:** Anomalous Sign-in Detected
- **Time:** 2026-03-30 16:41:30
- **Affected Account:** l.chen@nexusfinancial.thm
- **Corporate IP:** 197.32.45.112

After triaging the alert, Marcus marked it as a true positive and raised the following escalation ticket. A SIEM alert triggered on a successful sign-in to a Nexus Financial user account from an IP address that was never observed in the environment before. All Nexus Financial employees work from the London office (IP: 197.32.45.112) and are expected to sign in from the corporate network. This sign-in came from outside the United Kingdom. Laura Chen (Finance Manager) has confirmed she did not initiate this sign-in. Initial triage indicates this is a true positive requiring full IR investigation.

Escalation Details:

- **Ticket ID:** NXF-2026-0312 SOC
- **Raised by:** Marcus Webb, Security Analyst (L1)
- **Assigned to:** IR Analyst (L2)
- **Severity:** High
- **Affected Account:** l.chen@nexusfinancial.thm

In the previous three rooms, the investigation confirmed that this alert was the starting point of a targeted phishing attack against Nexus Financial. A phishing campaign delivered credential-harvesting emails to multiple employees. Two accounts got compromised. The attacker signed in from an IP address outside the UK, created a malicious inbox rule on the primary compromised account to suppress security alerts, accessed sensitive files in SharePoint, moved laterally to a second account through internal phishing, and exfiltrated data through external sharing. The incident has since been contained, the attacker eradicated, and the environment restored with improved controls in place.

Current IOC Tracker

The table below summarises all IOCs confirmed across the investigation.

IOC Type	Value	Hint (if starting from this room)
Attacker IP Address	[Found in the Detection and Analysis room]	Search Entra ID sign-in logs for <code>l.chen@nexusfinancial.thm</code> and look for sign-ins from outside the corporate IP <code>197.32.45.112</code>
Phishing Sender Address	[Found in the Detection and Analysis room]	Search Message Trace for emails delivered to <code>l.chen@nexusfinancial.thm</code> from external senders before the suspicious sign-in
Compromised Account 1	<code>l.chen@nexusfinancial.thm</code>	Confirmed in the SIEM alert above
Compromised Account 2	[Found in the Detection and Analysis room]	Search Entra ID sign-in logs for any other Nexus Financial accounts that show sign-in activity from the attacker IP
Malicious Inbox Rule	[Found in the Detection and Analysis room]	Search Unified Audit Logs for <code>New-InboxRule</code> operations on <code>l.chen@nexusfinancial.thm</code> from the attacker IP
SharePoint Files	[Found in the Response and Recovery room]	Search Unified Audit Logs for <code>FileDownloaded</code> operations from the compromised accounts

IOC Type	Value	Hint (if starting from this room)
External Email	[Found in the <u>Response and Recovery</u> room]	Search Unified Audit Logs for <code>SharingInvitationCreated</code> operations and check the target email address

Available Log Sources: Nexus Financial's Microsoft 365 logs have been ingested into Splunk under the index `ir`. The following log sources are available across all practical tasks in this room:

Log Source	Sourcetype	Key Fields
Entra ID Sign-in Logs	<code>azure:aad:signin</code>	<code>userPrincipalName</code> , <code>ipAddress</code> , <code>location.city</code> , <code>location.countryOrRegion</code> , <code>appDisplayName</code> , <code>status.errorCode</code>
Message Trace	<code>o365:reporting:messagetrace</code>	<code>Received</code> , <code>SenderAddress</code> , <code>RecipientAddress</code> , <code>Subject</code> , <code>Status</code> , <code>FromIP</code>
Unified Audit Logs	<code>o365:management:activity</code>	<code>Operation</code> , <code>UserId</code> , <code>Workload</code> , <code>ClientIP</code> , <code>ObjectId</code> , <code>SourceFileName</code> , <code>Name</code> , <code>SubjectContainsWords</code> , <code>DeleteMessage</code>

Task 6 - Post-Incident Review Practical

The attacker has now been contained, and the environment is clean. This task will bring together everything discovered across the investigation into a post-incident review. We will document the key findings for a technical summary, map the attacker's behavior to the MITRE ATT&CK framework, assess the incident's business impact, and build detection rules to ensure this attack is automatically detected in the future.

Some of these questions do not require Splunk. They test your understanding of what happened in the full investigation. The other ones will require you to go back to the logs to confirm specific values. Use the log sources, sourcetypes, and fields listed in Task 5 to build your queries where needed.

Documenting the Findings

The questions below represent the kind of findings that would appear in both the technical summary and the lessons learned report for the Nexus Financial incident. Work through them carefully. Together, they tell the complete story of the attack.

What Would Happen Next

The findings you document here would be used for two outputs. First is the technical summary, which would include the full IOC list, MITRE technique mappings, the timeline, and the root cause analysis. Second is the executive summary, which would highlight the business impact, regulatory considerations, and the controls being put in place to prevent recurrence. Both documents would be presented at the company's lessons learned meeting and used to drive improvements to its security posture.

Answer the questions below

| What was the initial attack vector used to compromise Laura Chen's account?

Phishing

| Even after the victim entered their credentials on the phishing page, what security control would have prevented the attacker from gaining access?

mfa

| How many employees were put at risk by the internal phishing email?

3

```
index=ir sourcetype="o365:reporting:messagetrace" FromIP="223.123.4.50"
```

```
| table _time Received, SenderAddress, RecipientAddress, Subject, Status, FromIP
```

Events	Patterns	Statistics (3)	Visualization										
Show: 20 Per Page  Format   Preview: On													
 _time 		Received 		SenderAddress 		RecipientAddress 		Subject 		Status 		FromIP 	
2026-03-30 16:57:09		2026-03-30T16:57:09.461Z		l.chen@nexusfinancial.thm		allan.senna@nexusfinancial.thm		HR Policy Update – Immediate Action Required		Delivered		223.123.4.50	
2026-03-30 16:57:09		2026-03-30T16:57:09.461Z		l.chen@nexusfinancial.thm		m.harris@nexusfinancial.thm		HR Policy Update – Immediate Action Required		Delivered		223.123.4.50	
2026-03-30 16:57:09		2026-03-30T16:57:09.461Z		l.chen@nexusfinancial.thm		k.patel@nexusfinancial.thm		HR Policy Update – Immediate Action Required		Delivered		223.123.4.50	

What was the first log source that identified the suspicious activity?

Entra ID Sign-in Logs

Which file downloaded by the attacker contains personally identifiable information of Nexus Financial employees?

Full_Employee_PII_Data.xlsx

```
index=ir sourcetype="o365:management:activity" Operation IN
(New-InboxRule,FileDownloaded,SharingInvitationCreated)
| table _time Operation, UserId, Workload, ClientIP, ObjectI
d, SourceFileName, Name, SubjectContainsWords, DeleteMessage
```

_time	Operation	UserId	Workload	ClientIP	ObjectId	SourceFileName
2026-03-30 16:55:24	FileDownloaded	l.chen@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/Finance-department/Shared Documents/Board_Meeting_Notes_July.docx	Board_Meeting_Notes_July.docx
2026-03-30 16:55:33	FileDownloaded	l.chen@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/Finance-department/Shared Documents/Employee_Salary_Data.xlsx	Employee_Salary_Data.xlsx
2026-03-30 16:55:37	FileDownloaded	l.chen@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/Finance-department/Shared Documents/Q3_Financial_Report.xlsx	Q3_Financial_Report.xlsx
2026-03-30 16:58:48	New-InboxRule	l.chen@nexusfinancial.thm	Exchange	223.123.4.50:13651	EURPR10A007.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/nexusfinancial.thm/363b8dd0-1f29-483b-90c4-00b1ea5ebfbf/Junk Filter Update	
2026-03-30 17:02:40	New-InboxRule	k.patel@nexusfinancial.thm	Exchange	223.123.4.50:25487	EURPR10A007.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/nexusfinancial.thm/eb11d9b1-3e98-49bf-b2c2-19a497641751/Security Updates	
2026-03-30 17:03:38	FileDownloaded	k.patel@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/HR-department/Shared Documents/Full_Employee_PII_Data.xlsx	Full_Employee_PII_Data.xlsx
2026-03-30 17:03:45	FileDownloaded	k.patel@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/HR-department/Shared Documents/Payroll_Q3_2024.xlsx	Payroll_Q3_2024.xlsx

For improving future detections, which Operation is relevant to highlight for detecting suspicious Inbox Rule Creations?

New-InboxRule

For improving the future detections, which field in Entra ID logs can be used to detect authentications coming from unusual countries?

location.countryOrRegion

Task 7 - Conclusion

In this room, we completed the final phase of the NIST SP 800-61r2 incident response framework. We reconstructed the full attack timeline, identified key indicators to build detection rules from IOCs collected throughout the investigation, and produced outputs that will make Nexus Financial stronger against future attacks. The lessons learned process does not end when this room ends. It feeds directly back into the Preparation phase, and the cycle begins again, better than before.

Throughout this IR module, we worked through a complete incident from start to finish. In the Preparation room, we reviewed Nexus Financial's preparation state and identified gaps in its processes. In the Detection and Analysis room, we detected and analyzed a live phishing attack targeting Nexus Financial, traced it to its source, and scoped the full compromise. In the Response and Recovery room, we contained the attacker, cleaned up their presence, and identified the root causes. In this room, we looked back on the lessons learned and summarized the whole incident for a good technical and executive summary report.

After this, the Nexus Financial will not be the same organization it was before this incident. The missing identity controls we saw in the first room would now be enforced. Email authentication controls would be configured. The detection rule gaps identified in the pentest report and confirmed by this incident would also be addressed. The IR policy would have an escalation timeline. The same attack that was successful before would now trigger multiple alerts within minutes.